1 Introduzione Generale alla Cybersecurity

1.1 Perché la Cybersecurity è una materia così complessa?

Sentiamo parlare ogni giorno di attacchi informatici e protezione dei dati, ed è facile intuire il motivo: più digitalizziamo le infrastrutture, i servizi pubblici e i processi produttivi delle aziende, più il valore di ciò che si trova online cresce. Di pari passo cresce anche l'interesse di chi vuole colpire questi sistemi.

Quando però ci si approccia allo studio della cybersecurity, ci si accorge subito che non si tratta di una scienza "compatta", lineare e ordinata, ma appare piuttosto **frammentata e difficile da sistematizzare**. Questa complessità non è casuale, ma deriva da due fattori principali:

1. **Un'evoluzione storica disomogenea:** la sicurezza non è nata a tavolino prima dei computer, ma ha dovuto costantemente "rincorrere" le innovazioni tecnologiche per tappare falle man mano che si presentavano.

2. **Una natura profondamente interdisciplinare:** per proteggere un sistema non basta scrivere buon codice, ma bisogna far dialogare mondi molto lontani tra loro.

1.2 Breve storia: dai Mainframe all'Internet of Things

Per capire perché i sistemi moderni siano così fragili, basta ripercorrere le tappe con cui si è evoluta l'informatica dagli anni '60 a oggi:

- **Anni '60 e '70 (L'era dei Mainframe):** i primi calcolatori esistevano solo in ambienti militari, governativi e scientifici. Erano macchine enormi e isolate; fare sicurezza significava essenzialmente chiudere a chiave la stanza del server, proteggere l'accesso ai terminali e gestire i privilegi dei pochi utenti autorizzati.

- **Anni '80 (Personal Computer e reti locali):** l'informatica entra negli uffici e nelle case. Con la diffusione dei PC e delle prime reti locali (LAN), il problema non è più solo chi accede fisicamente alla macchina, ma come proteggere i sistemi operativi e i dati salvati in ambienti distribuiti.

- **Anni '90 (L'esplosione di Internet e TCP/IP):** i computer iniziano a parlarsi su scala mondiale grazie al protocollo TCP/IP. La sicurezza assume una dimensione globale e nascono gli strumenti di difesa "classici" che conosciamo tutti: gli antivirus, i firewall per filtrare il traffico e i primi sistemi di rilevamento delle intrusioni (*IDS - Intrusion Detection System*).

- **Anni 2000 (Web, servizi online ed E-commerce):** Internet diventa una piazza commerciale. Non basta più bloccare un virus: bisogna proteggere le transazioni bancarie, applicare la crittografia avanzata su larga scala, gestire le identità degli utenti che comprano online e iniziare a tutelare giuridicamente i dati personali.

- **Anni 2010 a oggi (Mobile, Cloud e IoT):** con gli smartphone sempre connessi, il Cloud computing e l'*Internet of Things* (sensori industriali, auto connesse, domotica), i confini fisici sono spariti. La superficie d'attacco si è estesa a scala planetaria, rendendo la cybersecurity un problema sistemico che tocca le infrastrutture critiche (reti elettriche, ospedali, trasporti), l'economia globale e la geopolitica.

1.3 Frammentazione tecnica e multidisciplinarità

Poiché la cybersecurity si è sviluppata come un insieme di risposte specifiche a emergenze via via diverse, oggi ci troviamo in un ecosistema fatto di software, protocolli, standard e normative spesso non interoperabili tra loro. Basti pensare alla quantità di standard tecnici esistenti (**ISO/IEC 27001**, **NIST 800**, **CIS Controls**, linee guida **ENISA**), alla coesistenza di framework nazionali diversi e all'uso di tecnologie proprietarie chiuse che non sempre dialogano tra loro o sono verificabili dall'esterno. Se a questo sommiamo la rapidissima obsolescenza dell'hardware e del software, capiamo perché è così difficile costruire modelli di sicurezza universali.

Come se non bastasse, la cybersecurity si trova all'incrocio di almeno cinque grandi aree del sapere:

- **Informatica e Ingegneria:** forniscono gli strumenti pratici e architetturali per difendere reti, codice e sistemi.
- **Matematica e Crittografia:** mettono a disposizione le basi logiche e gli algoritmi per rendere sicure le comunicazioni e i dati.
- **Diritto e Governance:** stabiliscono le regole su responsabilità, privacy e conformità normativa (basti pensare a regolamenti europei fondamentali come il **GDPR**, la direttiva **NIS2** o il **Cyber Resilience Act**).
- **Scienze Sociali e Cognitive:** studiano il comportamento umano. Spesso dimentichiamo che l'essere umano è l'anello più debole della catena e il principale vettore di rischio attraverso gli attacchi di *ingegneria sociale* (come il phishing).
- **Economia e Gestione del Rischio:** permettono di valutare quanto costa un attacco in termini finanziari e strategici, aiutando a decidere quanto e dove investire in sicurezza.

Avere tante discipline coinvolte è una ricchezza, ma crea un problema enorme: **manca un linguaggio comune** (un'epistemologia condivisa). Un giurista, un matematico e un sistemista guardano allo stesso problema parlando tre lingue diverse.

1.4 Dalle fragilità del passato alle sfide di oggi

In sintesi, perché i nostri sistemi sono così vulnerabili? Perché poggiano su fondamenta storiche nate senza pensare alla sicurezza. Molti protocolli base di Internet sono stati progettati decenni fa dando per scontata una **fiducia implicita** tra i nodi della rete: l'obiettivo era far comunicare le macchine velocemente, non difendersi da attori malevoli.

Oggi paghiamo il prezzo di queste scelte, aggravato da:

- infrastrutture digitali sempre più complesse e stratificate;
- forte dipendenza da fornitori esterni e da catene di approvvigionamento (*supply chain*) globali: anche se la mia azienda è sicura, un attaccante può entrare passando dal software di un mio fornitore;
- carenza di figure professionali capaci di unire competenze tecniche, legali e gestionali.

Il risultato è che troppo spesso la sicurezza viene ancora trattata come un "accessorio" da aggiungere a fine progetto, anziché come una proprietà strutturale del sistema informativo fin dalla sua nascita (*security by design*).

2 L'Identità Digitale come Nucleo Centrale della Sicurezza

2.1 Perché partire proprio dall'identità?

Per mettere ordine in questo panorama così vasto, il punto di partenza più efficace è il concetto di **identità digitale**. L'identità è infatti il pilastro su cui poggiano tre meccanismi fondamentali di qualunque sistema sicuro:

1. **Autenticazione:** verificare chi sei
2. **Autorizzazione:** stabilire cosa hai il permesso di fare
3. **Responsabilità (Accountability):** poter ricollegare in modo certo un'azione a chi l'ha compiuta.

Inoltre, l'identità digitale non è un semplice dettaglio tecnico, ma è il perfetto punto di incontro tra tecnologia, diritto e società: racchiude il tema della fiducia digitale, della privacy e della responsabilità legale.

2.2 La triade fondamentale: Identificatore, Credenziale e Attributo

Quando progettiamo un sistema basato sull'identità, dobbiamo fare attenzione a non confondere tre concetti distinti che lavorano insieme:

- **Identificatore (Identifier):** è l'etichetta univoca che distingue un'entità digitale (una persona, ma anche un server o un sensore) da tutte le altre all'interno di un contesto. Esempi pratici sono lo username, l'indirizzo e-mail, il codice fiscale, una matricola universitaria o un *Decentralized Identifier (DID)* nelle reti basate su blockchain.
- **Credenziale (Credential):** è la "prova" che usiamo per dimostrare di essere i legittimi proprietari di quell'identificatore (es. una password, un certificato digitale, un token hardware, un'impronta digitale).
- **Attributo (Attribute):** è un'informazione aggiuntiva associata all'identità che ne descrive le caratteristiche, il ruolo o i diritti operativi.

Gli attributi sono particolarmente interessanti perché si dividono in due categorie:

- **Attributi statici:** cambiano raramente o mai (es. data di nascita, nome, codice fiscale).
- **Attributi dinamici:** cambiano frequentemente in base alla situazione (es. un ruolo temporaneo, l'orario di connessione, la geolocalizzazione del dispositivo o il livello di rischio del contesto di accesso).

Nei sistemi moderni, saper gestire gli **attributi dinamici** è la chiave per creare politiche di sicurezza intelligenti e adattive: i permessi di un utente non sono fissi per sempre, ma si adattano in tempo reale alle condizioni in cui sta operando.

2.3 Le tre architetture dell'identità: Centralizzata, Federata e Decentralizzata

Come vengono gestiti nella pratica gli identificatori e gli attributi? Esistono tre grandi modelli architetturali che si sono affiancati nel tempo:

1. **Architetture Centralizzate:** c'è un'unica autorità centrale che crea e gestisce gli identificatori e conserva tutti gli attributi in un database locale (gli esempi classici in azienda sono *Active Directory* o *LDAP*). È un modello comodissimo da gestire per l'amministratore e permette un controllo immediato, ma ha due grossi limiti: scala male quando devono collaborare organizzazioni diverse e crea un **punto unico di fallimento** (*Single Point of Failure*). Se cade o viene bucato il server centrale, si blocca tutto.

2. **Architetture Federate:** nascono per far dialogare organizzazioni diverse tramite rapporti di fiducia reciproca, usando standard aperti come **SAML**, **OAuth 2.0** e **OpenID Connect**. In questo modello troviamo due attori principali: l'*Identity Provider (IdP)*, che verifica l'identità dell'utente, e il *Service Provider (SP)*, che eroga il servizio. Quando usiamo **SPID** per entrare sul sito dell'INPS, o **eduGAIN** per accedere al Wi-Fi o alle biblioteche di un'altra università europea, stiamo usando un'identità federata: ci autentichiamo presso il nostro gestore di fiducia, il quale invia al servizio esterno un pacchetto di attributi firmati digitalmente che ci autorizza ad entrare.

3. **Architetture Decentralizzate (Self-Sovereign Identity - SSI):** è la frontiera più recente, basata su identificatori decentralizzati (**DID**) e credenziali verificabili (**Verifiable Credentials - VC**), spesso appoggiate su registri distribuiti o blockchain. Qui non c'è un server centrale che traccia dove andiamo: l'utente conserva i propri attributi certificati dentro un portafoglio digitale (*Wallet*) sul proprio dispositivo. Il grande vantaggio è la **divulgazione selettiva** (*selective disclosure*): posso dimostrare crittograficamente a un sito che sono maggiorenne o laureato senza dovergli inviare l'intera copia del mio documento d'identità, mantenendo il pieno controllo sui miei dati personali.

2.4 Casi d'uso reali: come lavorano insieme identificatori e attributi

Per capire quanto sia potente separare l'identificatore dagli attributi dinamici, vediamo cinque scenari concreti tratti dal mondo reale:

- **Caso 1 – Identità multiruolo in sanità:** immaginiamo un medico ospedaliero che fa anche ricerca universitaria. La persona fisica è una sola e usa un unico identificatore per fare login. Tuttavia, il sistema *IAM (Identity and Access Management)* legge il contesto operativo e assegna attributi dinamici diversi: quando il medico è in reparto (contesto clinico), l'attributo gli dà accesso alle cartelle cliniche complete dei pazienti; quando accede dal laboratorio di ricerca, i suoi attributi cambiano e gli permettono di vedere solo statistiche e dati rigorosamente anonimizzati.

- **Caso 2 – Deleghe temporanee nella Pubblica Amministrazione:** un dirigente deve andare in ferie per due settimane e delega il potere di firma a un funzionario. Nei vecchi sistemi, l'amministratore di rete dava i permessi a mano e spesso si dimenticava di toglierli al rientro del dirigente. Con gli attributi dinamici (magari gestiti tramite *smart contract* o policy automatizzate), l'attributo "delegato alla firma" ha una data di scadenza incorporata: allo scadere del tempo, il permesso decade da solo senza bisogno di intervento umano.

- **Caso 3 – Dispositivi IoT e attributi comportamentali (Smart Factory):** in una fabbrica intelligente, l'identità non riguarda solo gli umani. Ogni sensore sulla catena di montaggio ha un identificatore univoco e degli attributi che descrivono il suo comportamento normale (es. "invia un pacchetto di dati sulla temperatura ogni 5 minuti"). Se un sensore viene manomesso da un hacker e inizia a trasmettere mega-pacchetti di dati ogni secondo verso l'esterno, un sistema di analisi comportamentale (*UEBA - User and Entity Behavior Analytics*) nota subito che il comportamento viola gli attributi previsti e isola il sensore prima che faccia danni.

- **Caso 4 – Pseudonimizzazione e privacy differenziale:** nei portali scolastici o sanitari è fondamentale proteggere la privacy degli utenti mentre si analizzano i dati di utilizzo. Il sistema può generare identificatori temporanei (pseudonimi) diversi per ogni singola sessione di lavoro. In questo modo si separa l'identità anagrafica reale dai dati operativi: il sistema sa che "l'utente X ha svolto quell'attività" (mantenendo la tracciabilità tecnica), ma preserva l'anonimato della persona.

- **Caso 5 – Filiera agroalimentare o energetica su Blockchain:** in una rete logistica, i nodi (aziende agricole, trasportatori, sensori dei camion frigo) hanno come identificatore un DID. Gli attributi associati sono le certificazioni di qualità (es. "prodotto biologico", "origine verificata", "temperatura mai salita sopra i 4 gradi"). Ogni passaggio viene firmato crittograficamente: chi compra il prodotto finale può verificare tutta la catena di fiducia senza dover dipendere da un unico ente centrale.

In breve: l'*identificatore* garantisce l'unicità, gli *attributi* definiscono il contesto e i permessi, mentre l'*architettura scelta* determina come vengono gestite la fiducia e la scalabilità.

3 Il Valore dell'Identità nei Sistemi Distribuiti

3.1 Identità e Triade CIA nei sistemi moderni

Oggi quasi nessun sistema informatico è un blocco monolitico isolato; viviamo nell'era dei **sistemi distribuiti** (architetture cloud, reti di microservizi, IoT, blockchain). In questi ambienti non c'è un unico computer, ma tanti nodi indipendenti che devono comunicare tra loro attraverso la rete.

In un sistema distribuito, l'identità digitale assume un valore tecnico ed economico enorme perché è il meccanismo che crea la **fiducia distribuita**: ogni nodo (che sia un utente umano, un server o un'applicazione) deve poter riconoscere gli altri ed essere autorizzato prima di scambiare informazioni. Se un attaccante riesce a rubare o falsificare un'identità, cade l'intero castello di sicurezza, compromettendo i tre pilastri del modello **CIA**:

- **Confidentiality (Riservatezza):** chi ruba un'identità accede a dati segreti che non dovrebbe vedere.

- **Integrity (Integrità):** un nodo non autenticato (es. un sensore falso in fabbrica) può iniettare dati manipolati nel sistema, alterando i processi produttivi o decisionali.

- **Availability (Disponibilità):** se il sistema che gestisce le identità viene bloccato da un attacco, nessun utente o servizio riesce più ad autenticarsi e l'intera infrastruttura si ferma.

3.2 Classi di sistemi distribuiti e impatto sull'identità

A seconda di come è strutturato il sistema distribuito, cambiano radicalmente i problemi legati alla gestione delle identità. La Tabella 1 riassume le principali categorie architetturali e le rispettive implicazioni.

3.3 Analisi approfondita delle soluzioni nei sistemi distribuiti

Vediamo più da vicino i pregi, i difetti e i rischi concreti delle quattro soluzioni tecnologiche principali quando vengono calate nei sistemi distribuiti:

1. **Identità Centralizzata (es. Active Directory, Kerberos, LDAP):**

Classe di sistema	Esempio tipico	Caratteristiche	Implicazioni sull'identità
Client-Server	Database o portale aziendale interno	Controllo unico e autenticazione centralizzata	Gestione molto semplice, ma forte rischio di punto unico di fallimento (*Single Point of Failure*).
Multi-tier / Microservizi	Applicazioni moderne Cloud-native	Tanti piccoli servizi indipendenti che parlano via API	Non basta autenticare l'utente all'inizio: servono identità *service-to-service* e token di sessione leggeri tra i vari moduli.
Peer-to-Peer (P2P)	Reti Torrent, Blockchain pubbliche	Nodi tutti alla pari (equivalenti), senza un server centrale	L'identità è totalmente distribuita; il problema critico è che diventa molto difficile revocare un'identità compromessa.
Federato	SPID, eduGAIN	Domini autonomi che scelgono di fidarsi l'uno dell'altro	Richiede un forte coordinamento su policy, standard tecnici, ruoli e significato degli attributi scambiati.
Decentralizzato (SSI)	Wallet eIDAS 2	Identità autogestita direttamente dall'utente sul proprio device	Massima sovranità personale e privacy, ma elevata complessità tecnica e crittografica.

Table 1: Confronto tra le classi di sistemi distribuiti e le relative problematiche di identificazione.

- *Vantaggi:* l'amministratore ha tutto sotto controllo in un unico posto; fare *auditing* (controllare i registri di chi è entrato e quando) è semplicissimo.
- *Difetti:* scarsa scalabilità fuori dall'azienda e vulnerabilità concentrata.
- *Esempio di crisi reale:* se un attacco **ransomware** colpisce il controller di dominio Active Directory di un'azienda, l'intero sistema di login smette di funzionare. Anche i server che non sono stati infettati direttamente dal virus diventano inutilizzabili perché nessuno riesce più ad autenticarsi.

2. **Identità Federata (es. SAML, OAuth 2.0, OpenID Connect):**
   - *Vantaggi:* grande interoperabilità, riduzione drastica del numero di password che l'utente deve ricordare ed esperienza fluida grazie al *Single Sign-On (SSO)* (faccio login una volta sola e accedo a tanti servizi diversi).
   - *Difetti:* configurare i protocolli senza lasciare falle richiede molta competenza; inoltre è difficile mantenere sincronizzate le policy di sicurezza tra organizzazioni diverse.
   - *Esempio concreto:* grazie alla federazione europea **eduGAIN**, uno studente iscritto a un'università italiana può accedere ai database scientifici o alla rete di un ateneo tedesco usando direttamente le credenziali della propria università di origine.
3. **Identità Decentralizzata / Self-Sovereign Identity (DID e Verifiable Credentials):**
   - *Vantaggi:* l'utente è padrone dei propri dati, le attestazioni sono verificabili in modo indipendente in tutto il mondo senza dover contattare il server di chi le ha emesse.
   - *Difetti:* tecnologia complessa, norme giuridiche ancora in fase di consolidamento e, soprattutto, **difficoltà di recupero**: se l'utente perde il telefono e non ha fatto un backup sicuro delle sue chiavi crittografiche private, rischia di perdere l'accesso alle proprie credenziali senza avere un "call center centrale" a cui chiedere il reset della password.
   - *Esempio concreto:* un'università emette un diploma di laurea digitale firmato crittograficamente e lo consegna nel wallet dello studente. Quando lo studente fa colloquio con un'azienda, mostra la credenziale dal wallet: l'azienda verifica in un istante che la firma dell'università è autentica tramite blockchain, senza dover telefonare o accedere ai server della segreteria studenti.
4. **Identità dei Dispositivi nelle reti IoT:**
   - *Tecniche usate:* poiché un sensore non può digitare una password, si usano certificati digitali **X.509**, protocolli di autenticazione reciproca (**mutual TLS**, dove sia il sensore che il server si controllano a vicenda) e chip fisici di sicurezza saldati sulla scheda del dispositivo, come i moduli **TPM** (*Trusted Platform Module*) o **HSM** (*Hardware Security Module*).
   - *Sfide aperte:* i piccoli sensori hanno poca batteria e poca potenza di calcolo per eseguire calcoli crittografici pesanti; inoltre, aggiornare o revocare le chiavi di migliaia di sensori sparsi in una campagna o in uno stabilimento (spesso di marche diverse) è difficilissimo. Per questo si studiano soluzioni leggere basate su token simmetrici o *blockchain edge*.

Modello	Vantaggi principali	Limiti principali	Esempi tipici
Centralizzato	Facilità di controllo, auditing immediato	Punto singolo di fallimento, poca scalabilità	LDAP, Active Directory
Federato	Interoperabilità, delega di fiducia, SSO	Complessità di configurazione e manutenzione	SPID, eduGAIN
Decentralizzato (SSI)	Sovranità dell'utente, privacy avanzata	Recupero credenziali e chiavi molto complesso	eIDAS 2 Wallet
IoT-based	Alta scalabilità, automazione M2M	Risorse hardware/energetiche limitate, revoca difficile	Smart Agriculture, Industry 4.0
Ibrido	Bilancia controllo centrale e autonomia	Architetture articolate da progettare	Multi-cloud federato

Table 2: Quadro comparativo di sintesi dei modelli di gestione dell'identità.

4 Dall'Identità al Disegno Cyber di un Sistema Digitale

4.1 Il quadro normativo: perché la legge punta tutto sull'identità

Passando alla seconda parte del programma, notiamo subito un fatto interessante: tutte le principali normative e linee guida internazionali scritte negli ultimi anni per alzare il livello di cybersecurity mettono al centro proprio la gestione dell'identità. Le quattro pietre miliari da ricordare sono:

- **Regolamento eIDAS 2 (UE):** introduce l'*European Digital Identity Wallet* (il portafoglio di identità digitale europeo) per garantire a cittadini e imprese un'identità sicura, riconosciuta in tutti gli Stati membri e basata sul controllo dei propri attributi.
- **Direttiva NIS2 (UE):** obbliga le aziende che gestiscono servizi essenziali e critici (energia, trasporti, banche, sanità, digitale) ad adottare politiche rigorose di controllo degli accessi e autenticazione forte (multi-fattore).
- **NIST SP 800-63-3 (USA/Standard globale):** sono le famose linee guida sull'identità digitale che definiscono tre livelli numerici di garanzia e sicurezza:
  - *IAL (Identity Assurance Level):* quanto siamo sicuri dell'identità reale della persona nel momento in cui la registriamo per la prima volta?
  - *AAL (Authenticator Assurance Level):* quanto è robusto lo strumento (password, OTP, chiave biometrica) che l'utente usa per fare login ogni giorno?
  - *FAL (Federation Assurance Level):* quanto è sicuro il canale con cui i server si scambiano le attestazioni di identità in una federazione?
- **GDPR (UE):** impone i principi di *minimizzazione dei dati* (raccogliere solo gli attributi strettamente necessari allo scopo) e di trasparenza nel trattamento.

Non esistendo un modello di identità perfetto in assoluto, le architetture reali di oggi puntano quasi sempre su **soluzioni ibride**, che uniscono la comodità del controllo centralizzato con la flessibilità dei modelli federati e decentralizzati, restando conformi a queste quattro normative.

4.2 Allargare lo sguardo: Superficie di Attacco e Perimetro

Come facciamo ora a passare dal concetto specifico di "identità" alla progettazione della sicurezza dell'intero sistema digitale? Per fare questo salto logico dobbiamo introdurre due concetti cardine dell'architettura di sicurezza: la **superficie di attacco** e il **perimetro**.

4.2.1 La Superficie di Attacco (Attack Surface)

La **superficie di attacco** è l'insieme di tutti i punti, le interfacce, i canali e i processi attraverso i quali un attaccante può provare ad entrare nel nostro sistema o a danneggiarlo. Più un sistema è grande e interconnesso, più la sua superficie di attacco si allarga.

Per analizzarla bene senza dimenticare nulla, la dividiamo in tre categorie:

1. **Superficie tecnica:** comprende tutto ciò che è infrastruttura hardware e di rete, come porte di rete aperte, servizi esposti, protocolli di comunicazione, dispositivi IoT e il firmware delle macchine.

2. **Superficie logica:** riguarda il codice e i dati, quindi le applicazioni software, le interfacce **API** (spesso bersagliatissime), i database e il sistema stesso di gestione delle identità digitali.

3. **Superficie umana:** comprende gli utenti, i dipendenti, gli errori di distrazione, le procedure organizzative fatte male e la vulnerabilità agli inganni dell'ingegneria sociale.

Come si riduce la superficie di attacco? Con l'Hardening. Se immaginiamo un normale portale aziendale in cloud (che ha una pagina di login web, delle API REST per l'app mobile e un database interno), tutti questi punti di contatto formano la sua superficie di attacco. Il processo tecnico con cui "rimpiccioliamo" il bersaglio prende il nome di **hardening** (irrobustimento): consiste nel disattivare tutti i servizi software che non servono, chiudere le porte di rete inutilizzate, eliminare gli account di default e segmentare gli ambienti in modo che non tutto comunichi con tutto.

4.2.2 Il Perimetro di Sicurezza: dal muro fisico al confine logico

Il **perimetro di sicurezza** è invece il confine entro il quale un'organizzazione esercita il proprio controllo, protegge le proprie risorse e applica le regole di sicurezza.

La crisi del modello tradizionale ("Castello e Fossato"): Fino a qualche anno fa, il perimetro coincideva fisicamente con i cavi della rete interna dell'azienda o dell'università, difesi verso l'esterno da un grande firewall e da server proxy. Questo modello si basava su un presupposto molto ingenuo: tutto ciò che sta fuori dal firewall è "cattivo" (*untrusted*), mentre tutto ciò che è riuscito a entrare nella rete interna è automaticamente "buono e amico" (*trusted*).

Oggi questo modello è crollato per due motivi:

1. **Non c'è più un "dentro" e un "fuori":** con il Cloud computing, lo smart working, i dispositivi mobili personali e le identità federate (SPID, SSO), i dipendenti lavorano dal bar o da casa su reti non controllate dall'azienda, e i dati aziendali non sono più nello scantinato dell'ufficio, ma sparsi su server di terze parti in giro per il mondo.

2. **Il rischio dei movimenti laterali:** nel vecchio modello, se un hacker riusciva a bucare il firewall (magari mandando una mail di phishing a un singolo impiegato), una volta dentro la rete interna non incontrava più ostacoli e poteva muoversi liberamente da un server all'altro (*lateral movement*).

4.3 La rivoluzione Zero Trust (NIST SP 800-207): il Perimetro Identità-Centrico

Per superare i limiti del vecchio muro di rete, il NIST ha formalizzato nello standard **SP 800-207** il modello della **Zero Trust Architecture (ZTA)**.

Nel paradigma Zero Trust, il perimetro non scompare, ma cambia natura: **non è più una barriera fisica di rete, bensì una funzione logica dinamica costruita attorno all'identità, al dispositivo e al contesto**. Il motto alla base di tutto è **"Never trust, always verify"** (Non fidarti mai implicitamente di nessuno, verifica sempre ogni singola richiesta). Anche se un computer si trova fisicamente collegato col cavo dentro l'ufficio del direttore, il sistema non si fida di lui finché non supera tutti i controlli.

Il nuovo perimetro identità-centrico funziona combinando tre elementi in tempo reale:

1. **L'Identità:** chi sta chiedendo l'accesso? (Utente umano, dispositivo hardware o microservizio software). Serve a garantire autenticità e affidabilità.

2. **Il Contesto:** in quali condizioni sta avvenendo la richiesta? Il sistema valuta da quale rete proviene, la posizione geografica, l'orario della giornata, lo stato di salute del dispositivo (ha l'antivirus aggiornato?) e calcola un punteggio di rischio.

3. **Le Policy dinamiche:** sono il cervello decisionale. Invece di avere permessi fissi e statici, il motore di policy valuta Identità + Contesto in tempo reale e decide se concedere l'accesso, bloccarlo o chiedere una verifica aggiuntiva (es. un secondo fattore OTP).

Il concetto di Micro-perimetro: In un'architettura Zero Trust, ogni singolo nodo, risorsa o utente diventa di fatto un **micro-perimetro** indipendente, protetto dalle proprie regole specifiche di autenticazione e monitoraggio continuo.

Per esempio, se un docente universitario si collega da casa alle 10 del mattino col suo portatile registrato e si autentica con SPID per caricare i voti, il perimetro logico si "sposta" con lui e gli consente l'operazione. Se però la stessa identità del docente prova a scaricare l'intero database degli studenti alle 3 di notte da un indirizzo IP estero e da un computer sconosciuto, il contesto fa schizzare in alto il livello di rischio e la policy dinamica blocca immediatamente l'accesso.

Dimensione	**Modello Tradizionale (Fisso)**	**Modello Zero Trust (Dinamico - NIST)**
Confine di sicurezza	Coincide con il firewall o con la rete fisica interna.	È logico: definito da identità, dispositivo e contesto.
Fiducia (Trust)	Chi è dentro la rete interna è considerato implicitamente fidato.	Nessuna fiducia implicita (*Never trust, always verify*): ogni accesso va verificato.
Autorizzazioni	Statiche (una volta entrato, i tuoi permessi restano fissi).	Dinamiche, calcolate in tempo reale in base al livello di rischio della sessione.
Controllo	Centralizzato sul punto di ingresso della rete.	Distribuito su ogni risorsa e micro-perimetro.
Visibilità	Limitata a ciò che attraversa il perimetro fisico.	Completa e continua su utenti, dispositivi, applicazioni e singole sessioni.

Table 3: Confronto diretto tra l'approccio perimetrale classico e l'architettura Zero Trust.

4.4 Come si legano tra loro Perimetro e Superficie di Attacco?

Spesso all'esame viene chiesto qual è il legame esatto tra questi due concetti. Possiamo riassumerlo in modo molto chiaro così:

- La **superficie di attacco** ci dice *quanto il nostro sistema è esposto* (tutti i punti deboli tecnici, logici e umani che un attaccante può colpire).
- Il **perimetro** ci dice *dove e come noi esercitiamo il controllo* e applichiamo le regole di difesa.
- L'**hardening** lavora sulla superficie di attacco per ridurla al minimo indispensabile, rendendo più solido il perimetro.
- La **governance delle identità** e il modello **Zero Trust** trasformano il perimetro da un vecchio recinto statico a una rete di micro-perimetri intelligenti che seguono i dati e gli utenti ovunque vadano.

4.5 Esempio applicativo completo: l'infrastruttura Cloud di un Ateneo

Per vedere tutti i concetti delle due lezioni lavorare insieme, pensiamo a come funziona oggi il sistema informatico di una grande università:

- **Gli utenti e l'accesso:** migliaia di studenti, docenti e amministrativi si collegano da casa, dal treno o dalle aule usando i propri dispositivi personali. Accedono a servizi *SaaS* (es. posta elettronica, piattaforme per lezioni online, verbalizzazione esami) autenticandosi tramite identità federate o nazionali (**SPID**, **CIE**, **eduGAIN**, **eIDAS**).
- **L'infrastruttura ibrida:** i dati e i programmi non sono tutti in un unico posto, ma sono distribuiti tra i server fisici nei data center dell'ateneo e piattaforme di Cloud pubblico.
- **La difesa Zero Trust:** non potendo chiudere l'università dietro un unico firewall tradizionale, la sicurezza è affidata alle policy **IAM**. Quando uno studente fa login, il sistema verifica la sua identità, legge i suoi attributi (es. "studente iscritto al corso di Informatica"), controlla il contesto di connessione e crea un micro-perimetro logico che gli permette di vedere il materiale didattico del suo corso, ma gli impedisce totalmente di raggiungere i server amministrativi o i database degli stipendi dei docenti.